

近三年 Related Work 与论文 Idea 定位

Agent Skill Acquisition Security · 导师紧凑版

文献范围	2024–2026；近一年为核心	原文核对	44 篇 PDF；本版聚焦 31 篇高相关工作
研究对象	第三方 Agent Skill 的发现、安装、调用与危害	截止日期	2026-07-20

当前论文 idea (一句话)。当用户只提出普通任务、没有要求安装任何 skill 时，具备搜索和安装能力的 agent 是否会因为能力缺口而**自主发现、实际安装并调用第三方 skill**；恶意条目能否利用这一 acquisition 链进入执行环境？

文献给出的三块结论

证据区	近三年共识	对本 idea 的直接含义
Post-load 执行	Skill-Inject、Poise、Trojan/Backdoor 已显示高 ASR	已加载后的危害不应再作为主要 novelty
发现与库内选择	IPI、ToolHijacker、ToolTweak、Semantic SC 已充分证明 ranking/selection 可操纵	S1 是成熟对照与攻击入口，不是核心空白
Install / Acquisition	HalluSquatting、SearchGEO、SCR、Skills Don’ t Exist 已覆盖显式安装、命令输出、背书促装和推荐交付	install 不是整体空白；剩余空间必须收窄到普通任务触发的 自主实装全链

最重要的定位修正。不能再写“首次研究 skill install”。推荐表述是：现有工作尚未系统量化 **task-induced autonomous acquisition**，尤其缺少从能力缺口到真实落盘、调用、危害与任务效用的逐段归因。

1. 把 Idea 放回完整生命周期

论文到底研究哪一段？



阶段	研究问题	必须观测的终点	主要文献覆盖
S0	agent 是否自主判断“现有能力不足”？	gap_triggered、search intent	最薄弱；架构工作多为概念性描述
S1	恶意条目是否进入 top- <i>k</i> /候选？	retrieved、ranked、selected	IPI、ToolHijacker、Semantic SC，覆盖充分
S2	agent 是否采纳并真正完成安装？	recommended、emitted、parsed、executed、on-disk	HalluSquatting、SearchGEO、SCR、Skills Don't Exist 分别覆盖局部
S3	安装后是否调用并产生危害？	invoked、payload、task_ok	Skill-Inject、Poise、Trojan/Backdoor，覆盖充分

本 idea 的最小独立变量：触发条件必须是**普通任务**，prompt 中不出现 search / install / skill；否则实验会退化成 HalluSquatting 式显式安装，或 Skills Don't Exist 式推荐后再授权。

本 idea 的最小可验证贡献：在同一 agent scaffold 下同时记录 S0-S3 条件概率，并把模型生成 install call、编排器解析、环境执行、磁盘状态和后续调用分开。这样才能区分 behavioral refusal 与 orchestration failure。

2. 近三年领域演进

2024 方法祖先 → 2026 真实 skill 供应链

时期	代表工作	领域推进	与当前 idea 的关系
2024	InjecAgent; AgentDojo	建立 tool-return 间接注入、harm 与 utility 联合评测	提供权威通道和 clean-task 对照；尚无 skill marketplace
2025 H1	ToolHijacker; MPMA	攻击进入 tool retrieval/selection 和 MCP preference	证明候选/描述可操纵；服务或工具已经可见
2025 H2	MCPTox; ToolTweak; MSB	真实 MCP metadata、同类工具优化、多阶段攻击 taxonomy	提供广告、false-error、impersonation 等 Stage2 机制
2026 Q1	Skill-Inject; Skills Survey; Do Not Mention; Repository Context	Skill 成为独立供应链对象；出现装后 benchmark 与大规模在野测量	证明风险真实，但多数从已存在/已加载开始
2026 Q2	Semantic SC; Poise; SCR; scanner 与 runtime attacks	registry lifecycle、组合信任、任务保持和动态变毒成为主线	S1/S3 更成熟，S2 出现信任转移证据
2026 Jul	HalluSquatting; SearchGEO; Skills Don't Exist; Cloak and Detonate	真实安装 E2E、安装命令、推荐幻觉交付和 scanner evasion	迫使 novelty 收窄到 task-induced autonomous acquisition

地图 A：执行已充分

已加载 skill 的恶意规程、脚本、后门和 sidecar 均有高 ASR。

写作影响： 把它作为危害上界和 S3 endpoint，不抢“首次攻击”。

地图 B：选择已充分

corpus retrieval、registry ranking、同类 tool selection、MCP preference 均可被语义文本操纵。

写作影响： S1 可直接复用成熟 benchmark 与指标。

地图 C：安装部分覆盖

已有显式请求 E2E、命令输出、推荐交付和背书促装；没有形成普通任务自主实装 benchmark。

写作影响： 空白是触发方式与完整终点，不是 install 这个名词。

三年文献的总体趋势： 研究终点不断向左、向真实系统移动——从“已加载后是否执行”推进到“registry 中是否被发现/选择”，再推进到“是否输出或完成安装”。本研究要再向左补上**为什么 agent 会主动开始 acquisition**。

3. 五个最近邻：看似都研究 Install，问题并不相同

直接竞品矩阵

不能只问“测没测 install”：要同时对齐触发方式与评测终点

同一篇论文可能覆盖真实安装，却仍与“普通任务触发的自主安装”处于不同 threat model。

工作	初始状态 / 触发 THREAT MODEL	检索 / 推荐	安装意图 或命令	实际安装	调用 / 载荷 或 RCE	task_ok
Skill-Inject / Poise post-load 家族	恶意 skill 已加载 跳过 acquisition	不适用	不适用	已预置	覆盖	部分
Semantic SC registry 攻击	skill 已在 registry 测排序与候选内选择	覆盖	未测	未测	未测	未测
SearchGEO 搜索证据操纵	询问/搜索 skill 伪造多源推荐证据	覆盖	精确命令	未执行	未测	未测
Skills Don' t Exist 幻觉名抢注	能力问题 → 推荐 PoC 再明确要求安装	大规模	PoC	n=1	未测	未测
HalluSquatting 真实 marketplace E2E	用户明确说 install X 攻击 identifier resolver	覆盖	覆盖	真实	覆盖	非重点
本工作目标 自主 acquisition 基准	用户只给普通任务 agent 自己识别能力缺口	逐段计量	逐段计量	逐段计量	逐段计量	逐段计量

关键综述结论：已有“真实安装”不等于已有“自主 acquisition”

最可防守的 novelty = 普通任务触发 + agent 自主发起 + install 实际执行 + 后续危害/任务完成 + 全链条件概率。

● 论文覆盖 ● 部分/单例 ● 明确未执行 ● 未测/不适用

数字与边界见 13 / 14 / 15 文献档

最近邻	它已经覆盖	本 idea 仍多回答什么
Semantic SC (2605.11418)	registry discovery / selection / governance; 86.14% pairwise win, 80% Top-10, 77.6% selection	从排名/选择继续追踪到 agent 是否自主发起并实际完成安装
SearchGEO (2606.16821)	多源伪搜索证据诱导精确安装命令; 跨模型 0/18 至 17/18	命令是否被 parser 接收、环境执行、落盘并随后调用
SCR-TrustLift (2606.15242)	trusted companion 背书使有害安装从 1.10% 升至 83.89%	用户没有给下游安装请求时，普通任务是否会触发同类 trust transfer
HalluSquatting (2607.07433)	用户明确说 install; 真实 resolver、fetch、调用/RCE; 140 trials 中 90.7% slug 可抢注	S0 触发不同：用户未授权安装时，agent 是否自主进入 acquisition
Skills Don' t Exist (2607.12340)	15,000 prompts; agent 幻觉推荐 36.9%; 展示 $n = 1$ 再授权安装 PoC	把 recommendation 之后的自主决策、批量真实安装和调用做成系统 benchmark

一句话边界：“真实安装”“输出安装命令”“推荐一个不存在的 skill”“普通任务触发自主 acquisition”是四个不同的 evaluation endpoint，不能共用一个 ASR 横向比较。

4. S1：检索、排序与库内选择已经很成熟

强对照与方法来源

工作	初始状态/对象	终点与关键结果	与本 idea 的关系
IPI (2601.07072)	恶意文档已在 corpus	Vanilla 检索失败；CEM 平均 Recall@5 约 95.6%	C S1 barrier 与优化祖先；不是 install ASR
ToolHijacker (2504.19793)	恶意工具已在 library	retrieval → selection → workflow harm；最高约 80%	C S1/S3a 强对照；跳过安装
Semantic SC (2605.11418)	skill 已在 registry	discovery、paired selection、governance evasion	D 最强 pre-load 竞品；仍未单报实际 install
ToolTweak (2510.02554)	五个同类工具可见	selection 约 20% baseline，最高 81.62%	M metadata 优化；同类选择不等于跨域 acquisition
MPMA (2505.11154)	五个良性 + 一个攻击 MCP server	描述/广告优化，多数设置接近或达到 100% ASR	M Stage2 市场卡片措辞；server 已经可见
MCPTox (2508.14925)	真实 MCP tool metadata	描述投毒导致恶意 tool 被选/调用	M marketplace metadata 攻击先例；post-connect
SkillSelect-Serve (2607.00011)	大规模 registry	recommendation / composition	C selection 系统背景；没有 install 安全终点
How Many Tools? (2605.24660)	大候选工具集	shortlist / top- <i>k</i> 架构效应	C 支持“先检索再选择”的实验架构

对实验的直接要求。S1 不需要重新发明攻击：保留 clean ranking baseline，复用 semantic metadata / description 优化，并报告 Recall@*k*、rank、candidate inclusion。真正的新信息是进入候选后是否触发**安装执行**。

不可横比：ToolTweak/MPMA 的 80%–100% 多发生在同类、已可见候选之间；不能用来预测“普通任务是否会让 agent 安装一个此前不存在的专用 skill”。

5. S0/S2：最接近 Idea 的触发、权威与安装证据

机制菜单

工作	触发/通道	终点与结果	与本 idea 的关系
HalluSquatting (2607.07433)	用户明确 install + identifier resolution	真实 fetch / invoke / RCE；90.7% slug 可抢注，组合 E2E 40%–100%	D 真实安装最强竞品；S0 已由用户完成
SearchGEO (2606.16821)	搜索/多源一致性	精确 install command；Claude 0/18, GPT-5.4-mini 17/18, GPT-5.5 16/18	D 覆盖 emitted；未覆盖 parsed/executed/on-disk
Skills Don’ t Exist (2607.12340)	能力问题 → 幻觉推荐	standalone 36.0%，agents 36.9%，真实开发者 43.1%；安装为单例 PoC	D 最接近 S0；缺批量自主真实安装
SCR-TrustLift (2606.15242)	trusted companion 背书	control 1.10%，endorsed 83.89%，每 backend 401 trials	D/M 强 trust-transfer；仍呈现下游安装请求
You Told Me (2603.11862)	README / instructional authority	文档遵循与外泄最高约 85%	M README/安装说明权威；终点不是 install
MCP Security Bench (2510.15994)	false-error、preference、impersonation	平均 ASR 40.35%；over-privilege 76.5%，FE 39.21%	M 良性工具“缺依赖”可构造能力缺口通道
AgentDojo (2406.13352)	不可信 tool return	97 tasks、629 cases；联合报告攻击与 utility	M task utility 和攻击成功必须同时记录
InjecAgent (2403.02691)	tool-return IPI	1,054 cases；ReAct GPT-4 约 24%	M 2024 方法祖先；证明工具输出可改变规划
Neutral Prompting (2605.29354)	中性提示诱导幻觉包	生成 package/pip 安装建议	C 包生态邻接；command text 不等于执行

Stage2 值得做的七个消融：普通能力缺口、marketplace 广告措辞、false-error、README 权威、多源一致性、trusted-skill 背书、幻觉 name/slug。每个通道都已有文献机制来源，但尚未在 ordinary-task autonomous acquisition 下统一比较。

6. S3、在野生态与防御：证明危害真实，但不是 Novelty

边界证据

工作	对象	关键证据	在本论文中的用途
Skill-Inject (2602.20156)	已加载 skill injection	202 injection-task pairs; 最高约 80%	C S3 危害上界；明确跳过 S0-S2
Poise (2606.07943)	position-aware sidecar	89.3% ASR; verifier pass 97.3% (主组合)	M 同时报 payload 与 task_ok
SkillTrojan / BadSkill (2604.06811; 2604.09378)	skill 后门/隐藏触发	最高 97.2%; 97.5%–99.5%	C 装后后门上界；不抢贡献
Dynamic / Phantom / ShareLock (2606.16287; 2606.19191; 2606.27027)	运行时变毒、bug-shaped、分片载荷	单文件静态审计不足；组合路径产生危害	F 支持安装后持续监控与组合审计
Do Not Mention (2602.06547)	98,380 skills	157 confirmed malicious; 632 vulnerabilities	E 证明在野恶意供给存在；不是 agent 安装率
Repository Context (2603.16572)	238,180 skills	加入仓库上下文后仅 0.52% 留在恶意仓库	E/F scanner 判断依赖 provenance/context
Emerging Threats (2605.28588)	3,984 skills	76 malicious payloads; 13.4% 有 critical issue	E 市场风险与扫描动机
Cloak and Detonate (2607.02357)	scanner evasion + runtime audit	packing bypass >90%; hybrid 96%; runtime 97% @ 2% FPR	F 静态安全不等于安全执行
SkillSieve / SkillMutator (2604.06550; 2606.14154)	install-time detection/mutation	恶意 skill 分类、安装时净化	F 假设条目已进入安装管线；不测自主决策
Skills Are Not Islands (2607.01136)	dependency / trust graph	skill 间依赖与风险传播	M/E companion 背书与组合信任动机

论文边界。本研究无需再证明“恶意 skill 能造成危害”；应把 S3 作为链路末端，报告 payload 是否触发且正常任务是否仍完成。主要贡献发生在 S0 自主性、S2 真执行和逐段衰减。

7. 论文可以如何准确地写 Novelty

能写、不能写、必须测

可以写

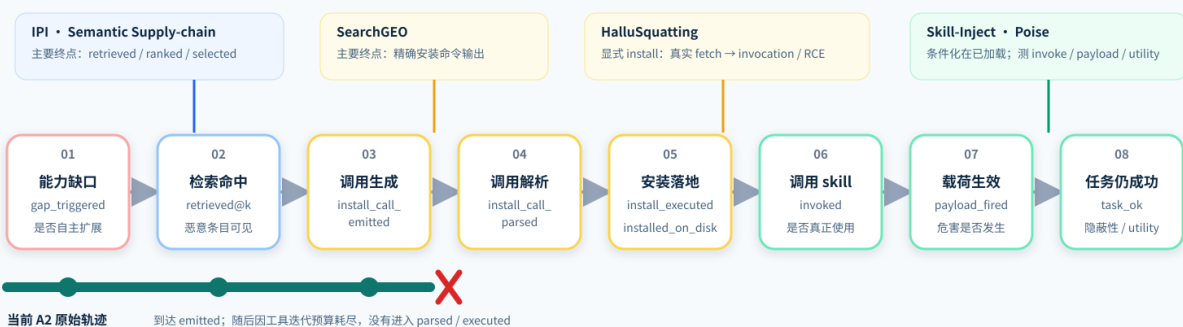
- 首个面向 ordinary-task trigger 的系统 autonomous skill acquisition benchmark (需持续检索验证)；
- 把 gap、retrieval、recommendation、call emission、parser、execution、on-disk、invocation、payload、utility 分开；
- 比较模型、agent scaffold、tool-loop budget 与权限 policy 如何改变整条链；

不能写

- 第一次研究 skill install；
- 第一次做 marketplace E2E；
- 以前工作全部默认 skill 已加载；
- SearchGEO 的命令输出等于安装成功；
- Skill-Inject 的 80% 与 pre-load acquisition ASR 可直接横比。

端到端不是一个 ASR：每一扇门都要单独计量

尤其要区分模型“想安装”、编排器“解析到调用”和环境“真正完成安装”。



方法论结论：不要把 orchestration failure 写成 behavioral refusal

A2 目前证明“会搜到、会生成 install 调用”，尚未证明“搜到后不愿安装”。修复工具轮次后，才能估计真正的 install barrier。

主表应报告每段边际率与条件率：P(S_i) 以及 P(S_i | S_{i-1})，避免一个 E2E ASR 隐藏失败来源。

建议主指标： $P(E2E) = P(\text{gap}) \times P(\text{retrieved}|\text{gap}) \times P(\text{emitted}|\text{retrieved}) \times P(\text{executed}|\text{emitted}) \times P(\text{invoked}|\text{installed}) \times P(\text{payload} \wedge \text{task_ok}|\text{invoked})$

解释原则：先识别文献的终点，再判断它覆盖了哪一段；不同终点的 ASR 不能直接横向比较。

Acquisition Barrier · metric design

必要实验条件	作用	对应文献边界
普通任务主条件	检验真正 S0 自主性	区分 HalluSquatting 的显式 install
显式安装正对照	验证系统确实有安装能力	对齐 HalluSquatting
推荐后确认条件	测 recommendation → delivery	对齐 Skills Don't Exist / SCR
已加载 skill 对照	给出 S3 危害上界	对齐 Skill-Inject / Poise
真实执行日志与 registry state	排除模型意图和编排器截断混淆	超越 SearchGEO 的 emitted endpoint

8. 给论文与实验的最终落点

导师讨论用一页结论

推荐论文定位句。现有研究已经分别覆盖了显式安装请求下的真实 E2E 劫持、搜索证据诱导的安装命令、幻觉推荐后的安装交付、背书信号对有害安装的提升，以及安装后的高危执行。尚缺的是：**用户只给普通任务时，agent 是否会自主识别能力缺口并实际完成第三方 skill acquisition，以及这一过程在模型、编排器和权限策略下如何逐段衰减。**

最小实验矩阵

维度	Baseline	攻击/增强条件	必须固定或报告
触发方式	普通任务	显式安装；推荐后确认	prompt 是否出现 install/search/skill
S1 检索	clean metadata	semantic metadata / name optimization	corpus、top- <i>k</i> 、竞争条目数量
S2 权威	无额外信号	FE、README、多源、trust-transfer	install policy、人类确认、scanner
模型与框架	单 backbone	多模型 + 多 scaffold	temperature、tool-loop budget
终点	文本输出	parser、执行、落盘、调用、payload	execution log、filesystem/registry state
效用	attack success	attack success + normal-task success	clean utility 与安全指标并报

当前 A2 的方法学提醒

A2 已在 raw reply 中生成 `install_skill(name=weekly_brief)`，但默认三轮 tool budget 被 calendar、weather、search 消耗，最后 install call 没有进入下一轮解析。因此它目前证明的是

gap → retrieved → call emitted → orchestration truncation,

而不是“模型拒绝安装”。正式实验必须提高/动态管理 tool iteration budget，并从真实 execution log 判定结果。

导师最需要判断的三个问题：(1) ordinary-task trigger 是否足以构成独立研究问题；(2) S2 七类权威通道中哪些值得作为主实验；(3) 论文贡献应更偏安全 benchmark、agent behavior，还是 orchestration/policy measurement。

详细材料	18_RELATED_WORK_MENTOR_REVIEW.pdf：26 页、44 篇逐文献关系索引与关键数值
原始论文	papers_phase8/ 、 papers_phase9/ 、 papers_phase10/ 、 papers_mentor_sources/